

Plantilla Excel para cálculo de IGM y ROI en gestión de vulnerabilidades basada en SSVC

Esta plantilla describe las hojas, campos y fórmulas recomendadas para implementar en Excel una medición cuantitativa del Indicador Global de Madurez (IGM) y del Retorno de la Inversión (ROI) del programa de gestión de vulnerabilidades alineado con SSVC. [web:27][web:32][web:16][web:20][web:33]

1. Estructura general del libro

Se recomiendan al menos cinco hojas:

1. Encuesta – Captura codificada de las respuestas.
2. Ponderaciones – Peso asignado a cada bloque de preguntas.
3. IGM – Cálculo de indicadores por bloque y global.
4. ROI – Estimaciones de costes, beneficios y ratios.
5. Dashboard – Visualizaciones y tablas resumidas.

2. Hoja “Encuesta”

Cada fila representa una organización (o unidad). Cada pregunta de la encuesta se codifica como un valor numérico (por ejemplo, 0–3).

Campos recomendados:

- Org_ID – Identificador de la organización.
- Sector, Tamaño, Ámbito – Variables demográficas.
- Una columna por pregunta: P1_1, P1_2, ..., P10_5.

Ejemplo de codificación (escala 0–3, de peor a mejor):

- P1_1: “¿Existe política formal?”
- No existe → 0
- Existe de facto → 1
- Formal pero desactualizada → 2
- Formal y revisada → 3

La codificación puede documentarse en una hoja adicional si se desea.

3. Hoja “Ponderaciones”

Define el peso de cada pregunta o, más simple, de cada bloque.

Columnas sugeridas:

- Bloque – 1, 2, 3, ..., 10.
- Peso_Bloque – valor de 0 a 1 que refleja su importancia relativa (la suma de todos debe ser 1).
- Opcional: Peso_Pregunta por cada pregunta dentro del bloque.

Ejemplo:

- Gobernanza (Bloque 1): 0,15
- Inventario (Bloque 2): 0,10
- Detección (Bloque 3): 0,10
- SSVC (Bloque 4): 0,15
- Puntos de decisión (Bloque 5): 0,15
- Acción/SLA (Bloque 6): 0,10
- Métricas/ROI (Bloque 7): 0,10
- NIS2 (Bloque 8): 0,10
- Automatización (Bloque 9): 0,03
- Cultura (Bloque 10): 0,02

Las ponderaciones pueden adaptarse según prioridades regulatorias o estratégicas. [web:33][web:39]
[web:27]

4. Hoja “IGM”

Objetivo: transformar las respuestas en un indicador de 0–100 por bloque y un IGM global.

4.1. Cálculo de puntuación por bloque

Para cada bloque:

6. Sumar la puntuación de sus preguntas.
7. Dividir por la puntuación máxima posible del bloque.
8. Multiplicar por 100.

Ejemplo (en Excel):

- Supongamos bloque 1 abarca P1_1:P1_5 (cinco preguntas, escala 0–3 → máximo 15).
- Para la organización en fila 2:

=SUMA(Encuesta!C2:G2)/15*100

Resultado → IGM_B1.

4.2. Cálculo de IGM global

El IGM global es una media ponderada de los IGM de cada bloque:

IGM_Global = SUMPRODUCTO(IGM_Bloques ; Peso_Bloques)

En Excel:

=SUMAPRODUCTO(IGM!B2:K2 ; Ponderaciones!B2:K2)

donde B2:K2 son los valores 0–100 de cada bloque y Ponderaciones!B2:K2 son los pesos.

4.3. Niveles de madurez

Se recomienda establecer bandas de interpretación:

- 0–25: Inicial / Reactivo.
- 26–50: Básico / Fragmentado.
- 51–75: Gestionado / Integrado.
- 76–100: Optimizado / Proactivo.

Estas bandas se pueden mostrar mediante formato condicional, iconos o gráficos de radar.

5. Hoja “ROI”

El ROI en gestión de vulnerabilidades no es una exactitud matemática, pero sí se pueden establecer aproximaciones razonables. [web:27][web:32][web:41][web:38]

5.1. Variables de entrada

- Coste_Herramientas – Licencias de escáneres, plataformas SSSVC, etc.
- Coste_Personal – Tiempo dedicado por el equipo (en €).
- Coste_Proyectos – Implementaciones específicas (segmentación, automatización).
- Coste_Incidentes_Antes – Estimación anual de pérdidas por incidentes relacionados con vulnerabilidades, antes de las mejoras.
- Coste_Incidentes_Despues – Estimación tras mejoras.
- Multas_Ahorro – Sanciones evitadas por cumplimiento (NIS2, sectoriales). [web:33][web:39]
- Otros_Beneficios – Ahorros operativos, reducción de tiempo de parada, etc.

5.2. Fórmulas sugeridas

- Coste_Total_Programa = Coste_Herramientas + Coste_Personal + Coste_Proyectos
- Beneficio_Anual_Estimado = (Coste_Incidentes_Antes - Coste_Incidentes_Despues) + Multas_Ahorro + Otros_Beneficios
- ROI = (Beneficio_Anual_Estimado - Coste_Total_Programa) / Coste_Total_Programa

Se pueden incluir horizontes de 3–5 años con VAN (valor actual neto) si se desea mayor sofisticación.

5.3. Relación con IGM

Puede explorarse la correlación entre IGM y reducción de incidentes:

- Clasificar organizaciones por cuartiles de IGM.
- Calcular media de Coste_Incidentes_Despues en cada cuartil.
- Visualizar tendencia: se espera, idealmente, que mayor IGM correlacione con menor coste de incidentes. [web:27][web:32][web:16]

6. Hoja “Dashboard”

Elementos sugeridos:

- Gráfico radar de IGM por bloque.
- Gráfico de barras comparando IGM entre organizaciones o unidades.
- Gráfico de dispersión IGM vs. coste de incidentes.
- Indicadores clave: IGM global, MTTR medio, % vulnerabilidades críticas en plazo, ROI estimado.

El dashboard permite explicar, en una diapositiva, por qué la organización no solo parcha, sino que prioriza y mejora de manera medible. [web:32][web:27][web:33]